

AMERICAN LATIN CLASS ATTENDANCE SYSTEM

Security Guide

Table of Contents

Security Guide

Authentication And Authorization

Session Security

Cache Privacy

Input Validation

Network And CORS

Secrets

Logging

Security Guide

Authentication And Authorization

- Google identity is verified server-side in production.
- The email/password endpoint `/auth/login` is for controlled academic Postman/manual verification and must be explicitly enabled with `POSTMAN_LOGIN_ENABLED=true`.
- Seeded manual users authenticate through `users.password_hash`; password hashes are never returned by `/auth/me`, `/users` or login responses.
- The role-test seed creates temporary credentials only for verification. Rotate or delete them before production use.
- Application roles are internal and are not derived from Google profile data.
- Protected endpoints use `requireAuth` or `allowRoles`.
- Resource access is scoped after role validation: BranchDirector users only see assigned branches through `user_branch_access`, Teacher users are limited to their own profile/classes, and Student users are limited to their own academic records.
- The Python Analytics API validates the shared session token and applies the same resource-scope checks before returning student, branch or teacher

analytics.

- Role updates are restricted to `Admin` and are audited.
- Branch access assignment is restricted to `Admin` and is audited.

Session Security

- Session cookie is HttpOnly and SameSite strict.
- Secure cookie flag is enabled in production.
- Only token hashes are stored server-side.
- Logout revokes the server-side session.
- Private pages and APIs send no-store cache headers.

Cache Privacy

- Sensitive session, user, attendance, evaluation and protected analytics responses use `Cache-Control: no-store, no-cache, must-revalidate, private`.
- Public cache is limited to non-secret metadata such as `/api/v1/auth/config` and the Python analytics health check.
- Private memory-cache entries include actor scope when the response can differ by role, branch assignment, teacher profile or student ownership.
- State-changing academic actions invalidate related memory-cache tags so repeated reads do not keep stale branch, attendance or report data.
- Cache behavior is visible through `X-Cache-Policy` and, for server memory cache, `X-Memory-Cache` headers.

Input Validation

- Zod validators centralize request body validation.
- Invalid bodies return `422`.
- Business conflicts return `409`.

Network And CORS

- `CORS_ORIGINS` must list only trusted frontend origins.
- Auth login route is rate limited by `AUTH_RATE_LIMIT_MAX`.
- In AWS, RDS must only accept traffic from API security groups.

Secrets

- No real secrets are committed.
- Production secrets belong in AWS Systems Manager Parameter Store or Secrets Manager.
- `.env.example` contains placeholders only.

- Production/staging runtime fails fast when required secrets are missing, weak, defaulted or when mock Google tokens are enabled.
- Postman demo passwords must be supplied locally or through a protected environment, not committed in the shared Postman environment file.

Logging

- API responses do not expose stack traces.
- Audit logs store action metadata but should not store raw tokens or sensitive evidence contents.